

Windows Server 2025 and Post-Quantum PKI – Michael Waterman

 michaelwaterman.nl/2026/05/15/windows-server-2025-and-post-quantum-pki

Michael Waterman

May 15, 2026



The advertisement features a dark blue background with a glowing shield icon in the center containing a padlock and the letters 'PKI'. To the left of the shield, the text reads: 'Microsoft', 'POST-QUANTUM CRYPTOGRAPHY', 'PREPARE YOUR PKI TODAY', 'FOR A QUANTUM-SAFE TOMORROW', 'THE TRANSITION HAS BEGUN.', 'SECURE YOUR IDENTITY. PROTECT YOUR FUTURE.' Below this, four icons represent 'POST-QUANTUM ALGORITHMS', 'AD CS READY', 'HYBRID & CLOUD', and 'OPERATIONAL EXCELLENCE'. A button at the bottom left says 'START PREPARING NOW. THE FUTURE WON'T WAIT.' To the right of the shield, four boxes list benefits: 'STRONGER SECURITY', 'IDENTITY PROTECTION', 'MODERNIZE YOUR PKI', and 'FUTURE-READY INFRASTRUCTURE'. At the bottom right, a quantum symbol icon is next to the text 'QUANTUM THREATS ARE COMING. LET'S STAY AHEAD—TOGETHER.'

Once upon a time, certificates were issued, systems trusted each other, smartcards authenticated users, VPNs connected remotely, web servers showed reassuring padlocks, and somewhere in a forgotten virtual machine or dusty rack server, a CA happily kept signing certificates while everyone collectively agreed not to touch it unless absolutely necessary. And to be fair, in most cases, that worked surprisingly well. Until suddenly... it didn't.

Over the last few years, PKI has been pushed far beyond what many environments originally designed it for. Certificate usage exploded. Identity became the new security perimeter. TLS is everywhere. Code signing became critical. Zero Trust architectures increased certificate dependency. And now, on top of all that, the industry is preparing for something that used to sound like science fiction:

Post-Quantum Cryptography. *(Insert some dramatic music)*

During the recent [Windows Server 2025 Summit](#) sessions, Microsoft shared a major update on their Post-Quantum roadmap for Active Directory Certificate Services (AD CS),

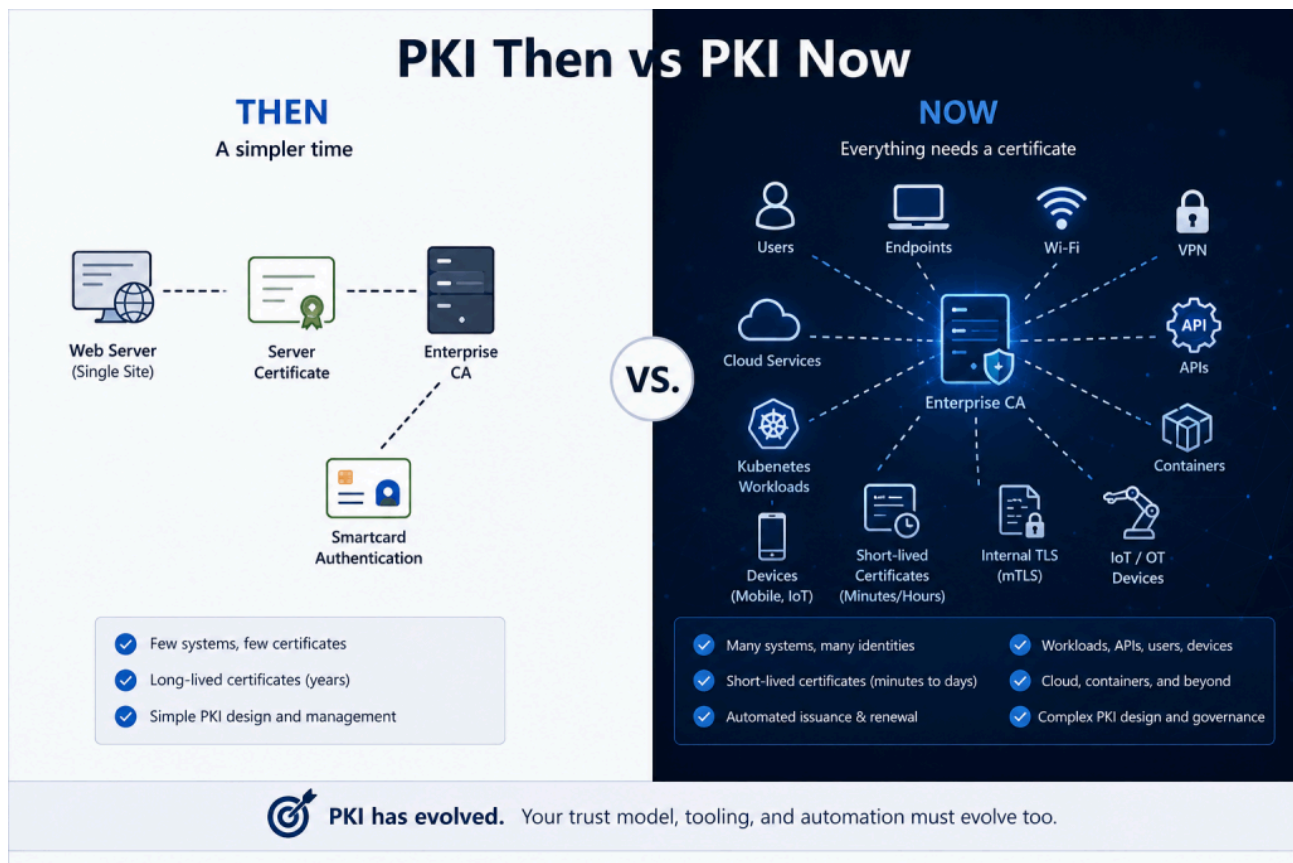
including the introduction of ML-DSA support in Windows Server 2025 and the first practical steps toward quantum-resilient PKI.



[Watch on YouTube](#)

And while the words “Post-Quantum” immediately trigger visions of futuristic cryptography labs and impossibly expensive quantum computers, the reality is actually much more practical, and much more uncomfortable at the same time. Because the biggest challenge is probably not quantum computing itself. It is the fact that many organizations are still dragging around cryptographic decisions made 15 or 20 years ago.

Past PKI was never designed for this scale



Traditional enterprise PKI was designed for a completely different era. Back then, certificates mostly lived on web servers, smartcards were still somewhat niche, and internal TLS was nowhere near as common as it is today (well, hopefully!). In many organizations, certificate lifecycle management was still a largely manual process. Renewals were scheduled in spreadsheets, certificate expirations became “*future someone else’s problem*,” and as long as the VPN stayed online and nobody touched the Root CA, life was generally considered good.

That world (should) no longer exists.

Today, certificates are everywhere. They authenticate users, devices, APIs, workloads, Kubernetes clusters, VPNs, Wi-Fi environments, cloud services, and increasingly even internal application communication. Modern infrastructures consume certificates at a scale many older PKI deployments were never originally designed to handle. And with the rise of short-lived certificates and automated issuance, the operational pressure on PKI environments has increased significantly. PKI is no longer just a supporting service quietly running in the background. It has become foundational infrastructure for identity, authentication, encryption, and trust across the entire enterprise ecosystem.

Interestingly, at the same time that organizations are looking at Post-Quantum cryptography, another major shift is happening in the PKI landscape. Public Certificate Authorities are gradually moving away from issuing certificates that support client

authentication scenarios. This is largely driven by changes in browser root program requirements, particularly from Google Chrome, which is pushing public PKI hierarchies toward server-authentication-only use cases. Several public CAs, including DigiCert, [Sectigo](#), and Let's Encrypt, have already announced timelines for removing the Client Authentication EKU from publicly trusted TLS certificates. And honestly, that changes the conversation around internal PKI quite a bit. Because suddenly, enterprise scenarios like:

- Wi-Fi authentication,
- VPN authentication,
- mutual TLS,
- workload identity,
- device authentication,
- and internal certificate-based access control,

are becoming increasingly dependent on private PKI again. As Microsoft highlighted during the Windows Server 2025 Summit, that growing dependency also introduces new operational challenges. Certificate volumes continue to rise, revocation becomes harder to manage at scale, TLS dependencies become stricter, and hybrid cloud environments introduce additional complexity around visibility and lifecycle management.

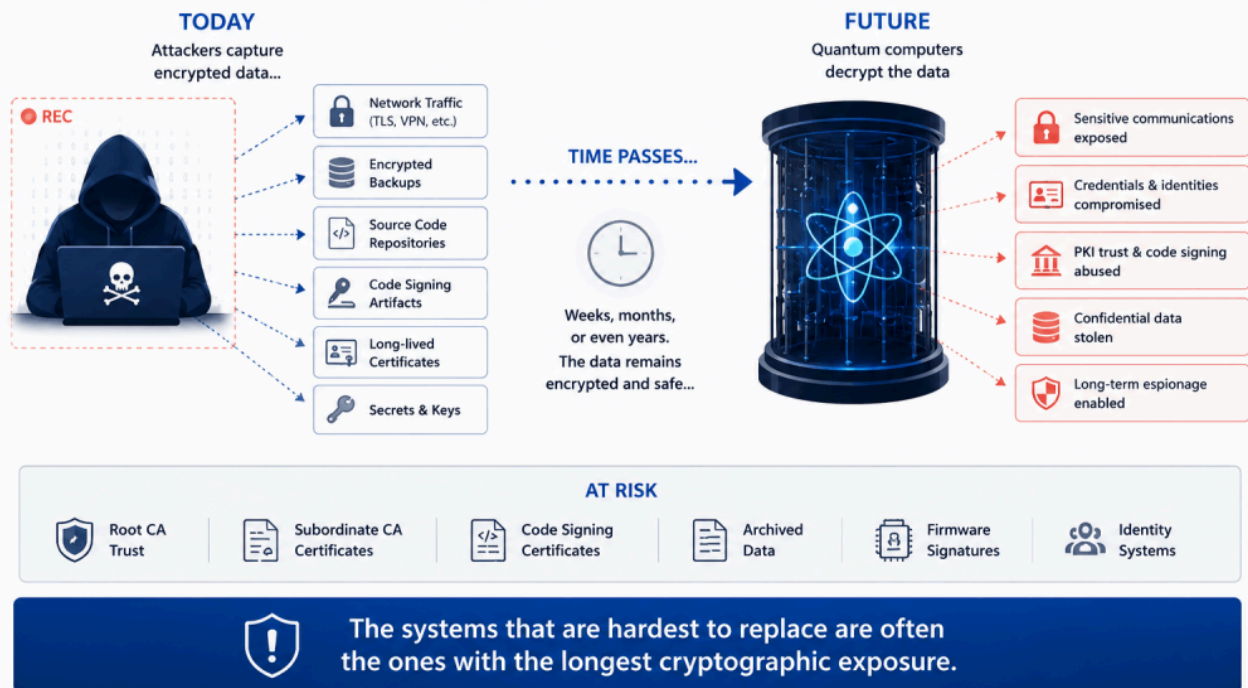
At the same time, organizations are expected to modernize their cryptography while still supporting systems that were designed long before phrases like “*Post-Quantum readiness*” even existed. And let's be honest: somewhere out there, there is still a production server running Windows Server 2008 R2 because “the vendor no longer exists and nobody dares to touch it.” PKI engineers know exactly how real that sentence is.

The Quantum threat is not really about today

One of the most important points Microsoft highlighted during the Windows Server Summit was something the security community has quietly been discussing for years: *Harvest Now, Decrypt Later*, often shortened to HNDL. The concern is not necessarily that quantum computers can suddenly break RSA or ECC tomorrow morning. Despite what some headlines may suggest, we are not at the point where attackers are casually decrypting TLS traffic over coffee. The real concern is much more subtle, and more realistic in my humble opinion.

Harvest Now, Decrypt Later (HNDL)

Attackers don't need to break encryption today.
They just need to save it for tomorrow.



Attackers do not need to decrypt sensitive data today if they believe they might be able to decrypt it in the future.

That completely changes how we should think about long-term trust and cryptographic exposure. Because once you start looking at it from that perspective, certain parts of enterprise infrastructure suddenly become far more important than many organizations realize. Root CA certificates, subordinate CA hierarchies, code signing certificates, archived encrypted backups, firmware signatures, identity systems, and long-lived secrets all share one uncomfortable characteristic, they tend to survive for a very long time.

And ironically, the systems that are hardest to replace are often the ones with the longest cryptographic lifetime. That is exactly why Microsoft is encouraging organizations to start preparing now instead of waiting for some dramatic “quantum apocalypse” moment where RSA instantly collapses overnight. Realistically, there probably will not be a single clearly defined turning point. The transition toward Post-Quantum cryptography will likely resemble every other major cryptographic migration we have seen over the past decades: slow, operationally painful, partially incompatible, and heavily dependent on vendor support and ecosystem maturity.

The migration away from SHA1 already demonstrated how difficult large-scale cryptographic transitions can become. Even after deprecation timelines were announced years in advance, many organizations still struggled to migrate in time because legacy applications, unsupported systems, embedded devices, and operational dependencies turned what looked simple on paper into a multi-year project. My guess is that Post-

Quantum migration will likely make the SHA1 transition look like a Sunday afternoon picnic in comparison.

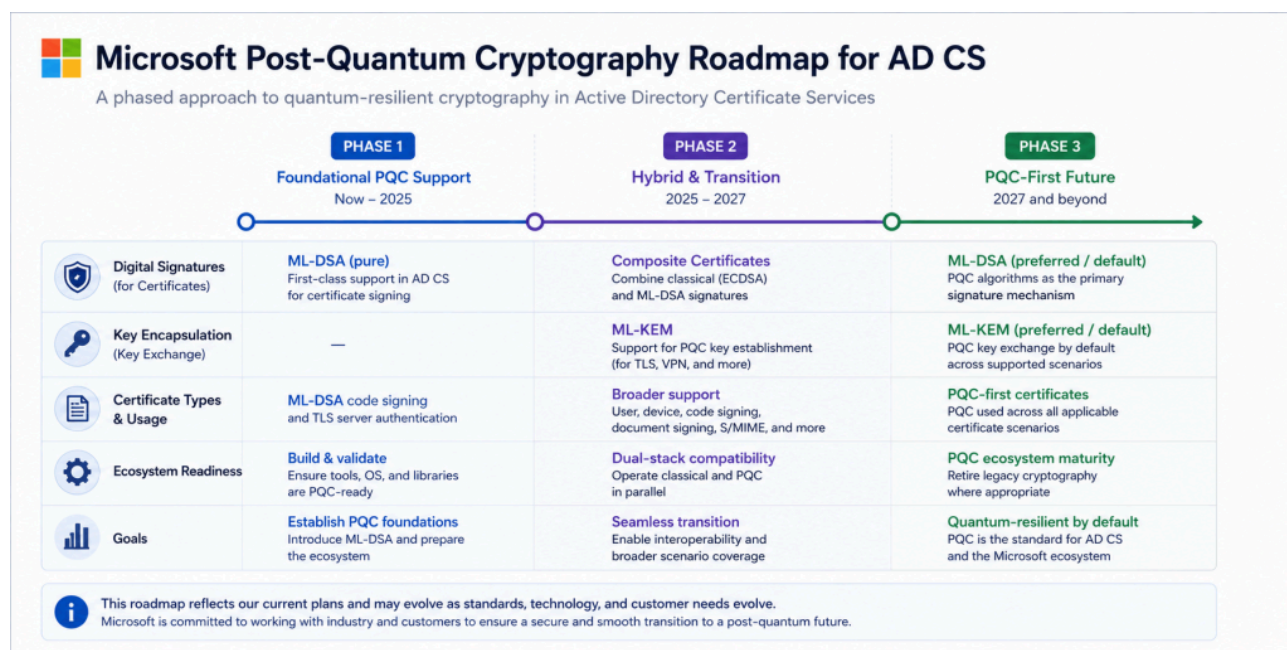
Microsoft's Post-Quantum direction for AD CS

During the Windows Server Summit session, Microsoft unveiled the first real phase of Post-Quantum support for Active Directory Certificate Services (AD CS) in Windows Server 2025. And for anyone working in enterprise PKI, this was one of those moments where you suddenly realize that Post-Quantum cryptography is slowly moving out of research papers and into actual infrastructure, at least I felt this way.

At the moment, Microsoft's primary focus is on signing scenarios using ML-DSA, short for *Module-Lattice-Based Digital Signature Algorithm*. Security professionals who have been following Post-Quantum cryptography for a while may recognize ML-DSA under its original research name, *CRYSTALS-Dilithium*. ML-DSA was standardized by NIST as part of the new generation of Post-Quantum cryptographic standards and is designed to provide quantum-resistant digital signatures for scenarios such as certificate signing, code signing, authentication, and integrity validation.

The current implementation in Windows Server 2025 focuses heavily on these signature-related scenarios. During the session, Microsoft demonstrated Post-Quantum certificate authorities, code signing workflows, OCSP signing, and experimental deployment scenarios using ML-DSA certificates throughout the chain.

What became very clear is that Microsoft is approaching this transition in phases rather than trying to force the entire ecosystem into Post-Quantum cryptography overnight.



The first phase introduces support for what Microsoft refers to as “*pure ML-DSA*.” To get started from the Windows platform point of view, Microsoft clarified some important

platform requirements during the session. For Certificate Authorities and OCSP responders, support currently requires Windows Server 2025 together with the May cumulative updates. This support is already available through [updates for Windows Server 2025](#) and primarily focuses on signature scenarios. On the client side, Microsoft specifically mentioned Windows 11 version 24H2 or later for post-quantum client scenarios.

The second phase, which is currently still under development, introduces support for composite certificates and ML-KEM, short for Module-Lattice-Based Key Encapsulation Mechanism.

Readers who have followed Post-Quantum developments over the last few years may recognize ML-KEM under its earlier and far more widely known research name: CRYSTALS-kyber ([Which makes my StarWars heart tick just a bit faster](#)). While ML-DSA focuses on signatures and identity validation, ML-KEM is designed for key establishment and confidentiality scenarios such as TLS encryption. One particular statement during the summit probably raised the blood pressure of quite a few PKI administrators.

Existing Certificate Authorities cannot simply be converted to ML-DSA afterward.

Instead, entirely new Certificate Authorities need to be deployed because the signature algorithm of an existing CA cannot be changed once it has been configured. That single detail immediately reveals the scale of what organizations may eventually be dealing with.

Because this is not the kind of migration where you simply enable a checkbox, restart a service, and call it “*cloud-native*.” (Did you feel the sarcasm?) A Post-Quantum migration potentially impacts the entire trust architecture of an organization. PKI hierarchy design, HSM compatibility, certificate templates, application support, revocation infrastructure, monitoring pipelines, vendor dependencies, compliance requirements, and long-term trust migration strategies may all need to be revisited. And that is before we even start talking about composite certificates.

One of the more fascinating technical aspects Microsoft demonstrated was the concept of combining classical cryptography with Post-Quantum cryptography inside a single certificate. These so-called composite certificates essentially contain both worlds at the same time. For example, a certificate could contain a traditional ECDSA signature alongside an ML-DSA signature, requiring both validations to succeed before the certificate is considered trustworthy.

At least conceptually, this creates a much stronger security model because an attacker would theoretically need to break both cryptographic systems simultaneously. In practice, however, this is where things are likely going to become extremely interesting.

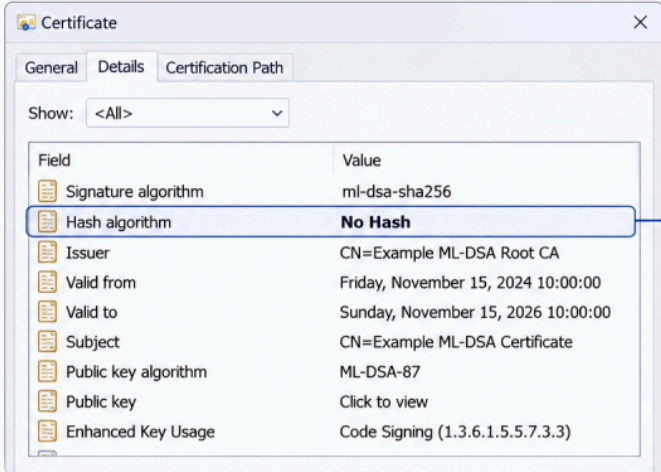
Because while the theory behind composite certificates is elegant, the reality of enterprise environments tends to involve legacy appliances, unsupported middleware, outdated TLS

inspection devices, embedded systems nobody fully understands anymore, and at least one Java application that mysteriously breaks whenever someone changes literally anything related to certificates.

Another detail that stood out during the summit was Microsoft's implementation of what they call "pure signing mode." Unlike traditional RSA or ECDSA certificates, ML-DSA does not require a separate external hashing algorithm during signing operations. As a result, certificates suddenly display something that feels deeply unnatural the first time you see it in a certificate viewer "*Hash Algorithm: NoHash*", Which looks slightly cursed the first time you encounter it.

Hash Algorithm: No Hash

Pure ML-DSA certificates do not use an external hash algorithm.



The screenshot shows a 'Certificate' window with the 'Details' tab selected. The 'Show:' dropdown is set to '<All>'. The following table represents the data shown in the details pane:

Field	Value
Signature algorithm	ml-dsa-sha256
Hash algorithm	No Hash
Issuer	CN=Example ML-DSA Root CA
Valid from	Friday, November 15, 2024 10:00:00
Valid to	Sunday, November 15, 2026 10:00:00
Subject	CN=Example ML-DSA Certificate
Public key algorithm	ML-DSA-87
Public key	Click to view
Enhanced Key Usage	Code Signing (1.3.6.1.5.5.7.3.3)

An arrow points from the 'No Hash' value to a callout box:

No external hash algorithm
ML-DSA performs hashing internally as part of the signature process.

Why this looks different (but is correct)



ML-DSA includes its own hashing internally.
No external hash selection is required or allowed.



The "No Hash" value is expected and indicates a pure ML-DSA signature.
This is by design.



Certificate viewers may look different, but the certificate is valid and standards-compliant.
(RFC 9480 / FIPS 204)

Microsoft also highlighted another practical challenge that will almost certainly become operationally relevant in larger environments, size. Post-Quantum public keys and signatures are significantly larger than traditional RSA or ECC equivalents. That increase impacts far more than just the certificate itself. Larger signatures and keys affect storage requirements, bandwidth consumption, CRL sizes, OCSP responses, certificate distribution, validation performance, and potentially even network appliances that were never designed with Post-Quantum cryptography in mind, and this is precisely why the current phase matters so much.



Signature & Key Size Comparison

Post-quantum algorithms provide stronger security, but come with larger keys and signatures.
Plan for the operational impact.

Algorithm	Public Key Size (bytes)	Signature Size (bytes)	Certificate Impact
 RSA 2048	~ 450	~ 256	 Baseline
 ECDSA P-256	~ 91	~ 64	 Small & efficient
Post-Quantum			
 ML-DSA-65 (Dilithium5)	~ 1,300	~ 2,420	 ~10x larger signatures
 ML-DSA-87 (Dilithium3)	~ 1,700	~ 3,300	 Even larger signatures
 ML-DSA-129 (Dilithium2)	~ 2,500	~ 4,600	 Significant operational impact

Operational Considerations



 Larger keys and signatures increase storage requirements.



More bandwidth needed for certificate distribution, CRLs, and OCSP responses.



May impact TLS handshake size and performance.



Monitoring, logging and tooling may require updates.

Not because organizations are expected to migrate their entire PKI tomorrow morning, but because this is the first realistic opportunity for enterprises to start understanding how Post-Quantum cryptography behaves inside real-world Windows environments before the migration eventually becomes unavoidable.

The enemy within, legacy crypto

Ironically, the biggest obstacle to Post-Quantum adoption may not be quantum computing itself, It is legacy infrastructure.

Throughout the Windows Server Summit session, Microsoft repeatedly emphasized that Post-Quantum readiness depends heavily on *modernization first*. Before organizations can realistically start deploying Post-Quantum cryptography at scale, several foundational pieces already need to be in place. That means moving away from legacy Cryptographic Service Providers (CSPs), adopting Cryptography Next Generation (CNG), modernizing toward TLS 1.3, using newer Windows versions, updating cryptographic APIs, and ensuring applications can support newer frameworks such as .NET 10. Many environments are still somewhere in the middle of that journey, if they have even started at all.

The Real Enemy: Legacy

Post-quantum cryptography is ready. Your infrastructure might not be.

Legacy systems, outdated protocols, and technical debt are the biggest threats to a successful PQC transition.



This is also the point where the entire Post-Quantum discussion suddenly becomes a lot less futuristic than people expect. Because once you move beyond conference slides and cryptography terminology, the real-world problems start looking very familiar. Organizations quickly discover that parts of their environment still depend on deprecated cryptographic providers, unsupported operating systems, legacy TLS versions, hardcoded certificate assumptions inside applications, outdated appliances, or HSM firmware that has not seen an update since somewhere around the invention of fire (this should end with a /s).

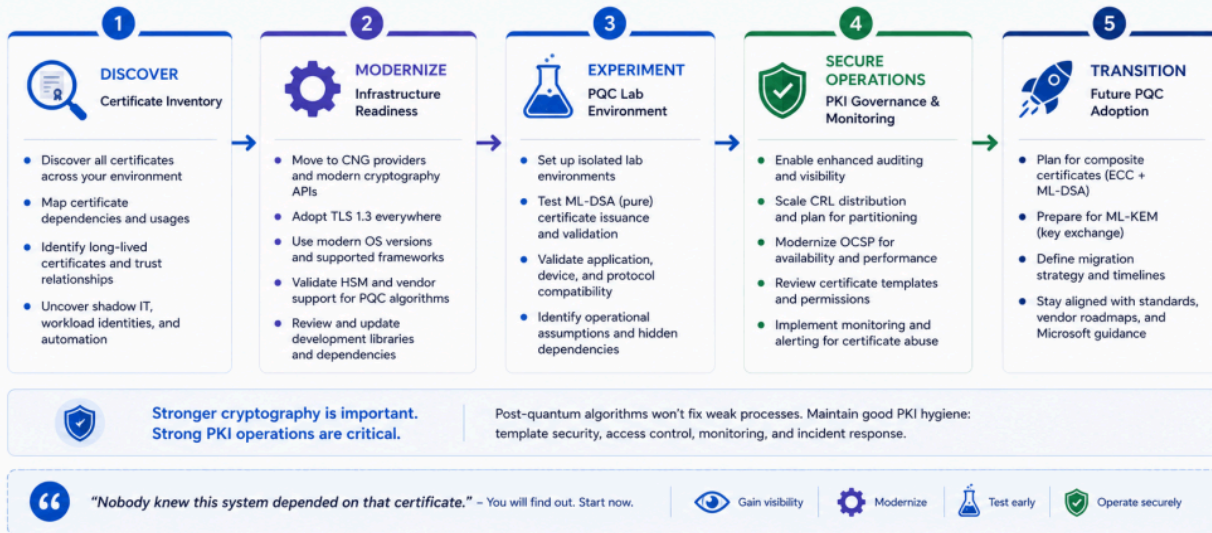
That is precisely why Post-Quantum readiness is not simply about introducing new algorithms like ML-DSA or ML-KEM. In many cases, it first requires organizations to untangle years of accumulated cryptographic dependencies that quietly became part of the infrastructure over time. The uncomfortable truth is that many organizations are already carrying a significant amount of cryptographic technical debt. Post-Quantum migration is simply forcing that reality into the spotlight.

Prepare your PKI for the Post-Quantum transition

The good news is that nobody is expected to replace their entire PKI environment tomorrow morning. Despite the growing attention around Post-Quantum cryptography, this is still the beginning of a very long transition. Most organizations are not even close to a full migration yet, and honestly, that is perfectly normal. What *is* important, however, is starting to prepare before the migration suddenly becomes urgent. The first steps have surprisingly little to do with quantum algorithms themselves.

Preparing Your PKI for the Post-Quantum Transition

A practical roadmap of what organizations should start doing **now**.



The most valuable thing organizations can start doing right now is gaining visibility into their existing cryptographic landscape. That means understanding where certificates are being used, which systems depend on them, how long trust relationships remain valid, and which applications still rely on older cryptographic assumptions. In practice, many environments contain far more certificate dependencies than teams initially realize, especially once workload identities, internal APIs, cloud integrations, and automated services enter the picture.

At the same time, organizations should start evaluating how modern their cryptographic foundation actually is. Microsoft repeatedly emphasized the importance of moving toward CNG providers, modern TLS implementations, updated operating systems, and newer development frameworks. HSM compatibility and vendor readiness are also becoming increasingly important, especially for organizations with long-lived PKI hierarchies or strict compliance requirements.

Another practical recommendation is to start experimenting in isolated lab environments. Not because organizations are expected to deploy Post-Quantum PKI in production immediately, but because testing is often the fastest way to uncover hidden dependencies and operational assumptions. And trust me, PKI environments are usually full of *"nobody knew this system depended on that certificate"* moments. Been there, done that, where's my t-shirt?

Microsoft also highlighted several improvements around AD CS itself that deserve attention regardless of Post-Quantum adoption. Enhanced auditing, scalable CRL partitioning, OCSP modernization, and improved visibility into certificate abuse scenarios may end up being just as important as the new algorithms themselves.

Because ultimately, stronger cryptography alone does not secure a poorly managed PKI.

An organization with perfect Post-Quantum algorithms but weak template permissions, poor monitoring, outdated revocation infrastructure, or uncontrolled certificate enrollment workflows is still going to have security problems. The cryptography may change, but the operational discipline behind PKI remains just as important as ever.

My thoughts on the summit

The quantum computer capable of breaking enterprise PKI is probably not sitting in someone's datacenter today. At least, hopefully not one connected to the internet with an expired management certificate and "admin/admin" as the default credentials. But regardless of when cryptographically relevant quantum computing truly arrives, the transition toward quantum-resilient cryptography has already started.

And if previous cryptographic migrations have taught the industry anything, it is that these transitions almost always take significantly longer than expected. Not because the mathematics are impossible to understand, but because enterprise infrastructure rarely moves at the speed security teams would like it to. Especially once cryptographic modernization collides with reality. And reality usually looks something like this, legacy infrastructure that cannot easily be replaced, operational dependencies nobody fully documented, vendor products that lag behind standards for years, compliance requirements that slow down every architectural change, and environments carrying decades of accumulated technical debt hidden deep inside authentication flows and trust relationships.

That is precisely why the announcements around Windows Server 2025 and Active Directory Certificate Services matter so much. Not because organizations are expected to replace their PKI tomorrow morning, and certainly not because RSA suddenly stops working overnight, but because this is the first realistic opportunity for enterprises to start experimenting with Post-Quantum PKI inside familiar Windows environments. That experimentation phase is incredibly important, start now!

Because trust infrastructure is usually one of the slowest parts of the enterprise to modernize once the pressure really starts building. Certificate hierarchies tend to live for years, sometimes decades. Applications become tightly coupled to existing trust models. Hardware Security Modules are not exactly known for rapid ecosystem changes. And somewhere in almost every organization, there is still a business-critical system nobody dares to migrate because nobody fully understands what will break if they do. That is also why waiting until Post-Quantum migration becomes urgent is probably the worst possible strategy, don't call me for that in 2034.

By the time the industry collectively decides the transition can no longer be postponed, most organizations will likely wish they had started preparing years earlier..... but hey, maybe that's just experience talking.